

Week 2: Footprinting & Reconnaissance

Networkwalks Cybersecurity & Ethical Hacking
Internship, Batch B083

This repo holds my work for the Week 2 project modules (1, 2 and 4). The theme of the week is recon: finding out as much as you can about a target using only public information, before anything gets scanned or attacked. Nothing in here exploits anything. It's all just reading what's already out there, which is the whole point of the exercise.

Screenshots and raw text output for every task are in the module folders (layout is at the bottom).

Modules

Module	Topic	Tools
W2-PM1	Footprinting with multiple Kali tools	whois, whatweb, nslookup, curl, wafw00f, dnsrecon

Module	Topic	Tools
W2-PM2	Footprinting with the Google Hacking Database	GHDB on Exploit-DB, Google dorks
W2-PM4	Footprinting with theHarvester	theHarvester 4.10.1

Setup

Everything was done from a Kali Linux VM. All the tools come preinstalled, so there was nothing to set up beyond opening a terminal. wafw00f was v2.4.2 and theHarvester was 4.10.1.

W2-PM1: Multiple Kali tools

Target: `networkwalks.com` (the site the course gives as the lab target).

```
whois networkwalks.com
whatweb networkwalks.com
nslookup networkwalks.com
curl -I https://networkwalks.com
wafw00f networkwalks.com
dnsrecon -d networkwalks.com
```

What each tool told me

whois: The registrar is GoDaddy. The domain was created on 6 Nov 2019 and expires on 6 Nov 2027. The name servers are `ns6135.hostgator.com` and `ns6136.hostgator.com`, which gives away the hosting provider straight away. DNSSEC is unsigned, and the usual client-side transfer/update/delete locks are set.

whatweb: It's running Apache with WordPress (7.0.4) and the WP Download Manager plugin (3.3.58), plus jQuery 3.7.1. HTTP gets redirected to HTTPS. The output also leaks the server IP (192.232.216.135) and a contact email address.

nslookup: Using Google's resolver (8.8.8.8), the domain resolves to 192.232.216.135. It's a non-authoritative answer, which is expected since it came from a public resolver and not the domain's own name server.

curl -I: Returns `HTTP/2 200` with `server: Apache`. The headers also show a couple of caching hints (`x-nginx-cache: WordPress`, `x-endurance-cache-level`), a `Link` header pointing at the WordPress REST API (`/wp-json/`), and a `__wpm_client` cookie set with `secure; HttpOnly`.

wafw00f: Says the site is behind ModSecurity (SpiderLabs) and it only needed 2 requests to figure

that out.

dnsrecon: Found the SOA, the two NS records, an A record, an MX record (`mail.networkwalks.com` , same IP as the site), TXT records (an SPF policy and a Google site verification), and 8 cPanel autodiscover SRV records. It also picked up the DNS software version, BIND 9.16.23-RH.

Putting it together

Combining everything gives a pretty complete picture: a WordPress site on HostGator (cPanel) hosting, running Apache, behind ModSecurity, with mail handled on the same server. If I were on the attacking side, the next thing I'd do is look up that WordPress version and the plugin version in vulnerability databases, and I'd expect anything noisy to get blocked by the WAF. If I were defending it, I'd want to hide version numbers, and think about whether the REST API and the DNS version banner really need to be that visible.

W2-PM2: GHDB (Google dorks)

GHDB is a big collection of ready-made Google search queries ("dorks") hosted on [exploit-db.com](https://github.com/0x00sec/ghdb). The idea is that Google has already indexed a lot of stuff

people didn't mean to make public, and the right query surfaces it without ever touching the target.

The workflow for both tasks was basically the same:

1. Open Exploit-DB and go to **GHDB** in the left menu
2. Search for a keyword (I used `cam` for the cameras)
3. Copy a dork, paste it into Google
4. Open the results one by one and check whether they're actually what the task asks for

Task 1: exposed cameras

The example dork from the guide is:

```
intitle:"webcamXP" inurl:8080
```

I've kept the actual list of camera addresses out of this repo on purpose. These are real devices belonging to real people, and posting a list of them on a public GitHub page isn't fair to the owners. The table with the links and dorks is part of the report I submitted instead.

Task 2: math ebooks in PDF format

The dork for this one is:

```
intitle:index.of "parent directory"
```

```
mathematics pdf
```

It finds open directory listings that contain math PDFs. A good example result is

<https://www.skylineuniversity.ac.ae/pdf/math/> , which is a university folder you can browse without any login. My full list of 10 is in `module2-ghdb/task2-math-ebooks.md` .

W2-PM4: theHarvester

theHarvester collects emails, sub-domains and hosts from public sources like search engines. It's passive, so the target isn't contacted directly. Target for both tasks: `microsoft.com` .

```
# Task 1: Baidu only, limit 1000
theHarvester -d microsoft.com -l 1000 -b
baidu

# Task 2: all sources, limit 50
theHarvester -d microsoft.com -l 50 -b all
```

Flags: `-d` is the domain, `-l` limits the number of results, and `-b` picks the data source.

Task 1 (Baidu): Not much came back. It found no IPs, no hosts and just one email address (`viva-`

`noreply@microsoft.com`), which is a no-reply address and not a real person.

Task 2 (all sources): This one is much noisier. Lots of the sources (bevigil, Bitbucket, bufferoverrun, BuiltWith, Brave and others) need an API key, so the terminal fills up with "Missing API key" errors when they get skipped. The lesson for me was that `-b all` isn't really "everything" unless you've set up keys in `/etc/theHarvester/api-keys.yaml` .

The guide also notes that results can differ from run to run, since the sources keep changing.

What I took away from this week

- Every tool by itself gives a small piece, but together they build a full profile of a target very quickly.
- None of it involved attacking anything. That's exactly why recon is hard to detect and why it's worth doing on your own systems first.
- Version numbers, banners and DNS records are easy to overlook, but they're exactly what an attacker would go looking for.
- Different data sources give different results, so it's worth trying more than one.

Repo layout

```
.
├── module1-multiple-tools/
│   ├── screenshots/
│   └── outputs/
├── module2-ghdb/
│   └── task2-math-ebooks.md
├── module4-theharvester/
│   ├── screenshots/
│   └── outputs/
└── README.md
```

Disclaimer

This is for learning only. Everything here was done as part of the Networkwalks course, using tools and targets the course set up, and only on public information. Don't run any of this against systems you don't own or don't have written permission to test.